

ASSIGNMENT

2110413 COMPUTER SECURITY

Assignment 3
Access Control

Computer Engineering, Chulalongkorn University

Worralop Srichainont

Student ID: 6632200221

September 7, 2026

Contents

1	Part I: Security Policy	1
1.1	Confidentiality	1
1.2	Integrity	1
1.3	Availability	1
1.4	ConflictOfInterest	1
1.5	Rules	2
2	Part II: Subjects and Objects	3
2.1	Subjects	3
2.2	Objects	3
3	Part III: Access Control Model	4
4	Part IV: Access Control Matrix	5
4.1	MatrixAcademic	5
4.2	MatrixResearch	5

1 Part I: Security Policy

A security policy is just a set of rules that say who can do what. We split our rules into four goals: confidentiality, integrity, availability, and conflict of interest.

1.1 Confidentiality: Keep Student Data Private

- A student can see only their own profile, grades, and registration.
- A faculty member can see students only in their own course.
- Registrar staff can see records they need for their job, not everything.
- Research data is shared only with people who are allowed to see it.

1.2 Integrity: Keep Grades and Records Honest

- Only faculty can enter grades, and only for their own course.
- Students can never write or change a grade.
- Grade changes happen only inside the grading period, and get logged.
- Registration and transcript records can change only through approved steps.

1.3 Availability: Keep the Portal Working

- Students and faculty can reach registration and grades during normal hours.
- The system is backed up, so IT staff can restore it if something breaks.

1.4 Conflict of Interest: Keep Research Separate

- If a researcher works with one company's or group's private data, they cannot also work with a rival group's private data.
- A researcher must pick one side before touching sensitive research data.

Definition: three ground rules

Least privilege: give each user only the access they need, nothing more. **Separation of duties:** split sensitive tasks so one person cannot do everything alone (e.g. entering a grade and approving it). **Default deny:** if a rule does not clearly allow something, the system blocks it.

1.5 Simple Rules by Role

- **Student:** read own data, read own grades, request own registration. Nothing else.
- **Faculty:** read/write grades and materials, but only for their own course.
- **Registrar:** read/write registration and official records, no research data.
- **Researcher:** read/write one research group's data at a time, never two rival groups.
- **Admin:** manage accounts and settings, but not routine access to grades or research data.

2 Part II: Subjects and Objects

In access control, a **subject** is who is asking for access. An **object** is what they are trying to access.

Definition: subject vs. object

A **subject** is an active user or process that requests access, like a student logging in. An **object** is a passive resource being protected, like a grade record.

2.1 Subjects: Who Is Asking

- Student
- Faculty (instructor)
- Registrar / academic staff
- Researcher
- System administrator

2.2 Objects: What Is Being Protected

- Student profile and personal data
- Registration records
- Grades and transcripts
- Course materials and faculty collaboration files
- Research datasets (grouped by which side the researcher is on)
- Audit logs
- System settings

3 Part III: Access Control Model

We pick **Role-Based Access Control (RBAC)** as the main model. Here is why:

- The portal already has clear roles: student, faculty, registrar, researcher, admin.
- In RBAC, access is tied to the role, not to each person one by one. Easier to manage.
- Least privilege is simple: give each role only what that role needs.

Note: research needs one extra rule

RBAC alone is not enough for the conflict-of-interest rule, because that rule depends on **history**: once a researcher touches Group A's data, they must be blocked from Group B's data afterward. This is exactly what the **Chinese Wall model (Brewer–Nash)** is built for. So we add a Chinese Wall on top of the Researcher role: once a researcher picks a side, the wall blocks the other side.

Note: why not Bell-LaPadula or Biba alone

Bell-LaPadula and Biba use fixed security levels (like “secret” or “high integrity”). They do not naturally handle “only my own course” or “pick one side and stay there”. RBAC plus Chinese Wall fits this scenario better.

Key Takeaway

Main model: RBAC, one role per type of user. Extra rule: Chinese Wall for researchers, so no one can see both sides of a conflict of interest.

4 Part IV: Access Control Matrix

An access control matrix lists every subject as a row and every object as a column. Each cell shows what that subject can do to that object.

Legend

R = read, **W** = write/update, **C** = create, **O** = owns the record, **–** = no access.

4.1 Academic Objects

Subject	Own Profile	Other Profiles	Registration	Own/Assigned Grades	Other Grades	Course Materials
Student	R, W, O	–	R, C	R	–	R
Faculty	R, W	–	R	R, W	–	R, W
Registrar	R	R	R, W	R, W	R, W	–
Researcher (Group A)	R, W	–	–	–	–	R, W
Researcher (Group B)	R, W	–	–	–	–	R, W
Admin	–	–	–	–	–	–

Table 1: Access rights for student, registration, and course-material objects.

4.2 Research and System Objects

Subject	Research A	Research B	Audit Logs	Config
Student	–	–	–	–
Faculty	–	–	–	–
Registrar	–	–	R	–
Researcher (Group A)	R, W	–	–	–
Researcher (Group B)	–	R, W	–	–
Admin	–	–	R, W	R, W

Table 2: Access rights for research datasets and system objects.

Key Takeaway

Every blank cell is a deny by default. A researcher who chose Group A never gets a cell filled in under Group B, and the other way around. This is the Chinese Wall rule shown as a table.